J&J ACELERAÇÃO CYBERSECURITY

Identity and Access Management (IAM)

Identidades não humanas (serviços, chaves e tokens)

Material didático do aluno

Módulo IAM: 40 horas | Semanas 4-5
Aula: 4 horas | Nível básico/intermediário

Objetivo de aprendizagem

Gerenciar identidades de serviço.

Aprenda a reconhecer quem atua em nome de uma aplicação, limitar suas permissões e acompanhar sua identidade desde a criação até o encerramento.

Aprendizagem pela prática

Quadros comparativos, exemplos corporativos, microtarefas, laboratório de análise, estudo de caso e desafio de arquitetura. Todas as atividades usam dados fictícios, sem conta cloud paga e sem segredos reais. Não há gabarito.

2026

Edição de estudo | Português brasileiro

1. Percurso da aula de 4 horas

Nas aulas anteriores, o foco foi a identidade digital e o controle de acesso. Agora, o sujeito do acesso pode ser um programa que executa milhares de operações sem uma pessoa diante da tela. A responsabilidade por esse programa continua sendo humana.

Tempo	Etapa e páginas	Produção do aluno
0-35 min	Fundamentos e credenciais (3-5)	Vocabulário e microtarefas 1-3.
35-70 min	OAuth, JWT, chaves e certificados (6-9)	Análise de limites do acesso.
70-105 min	Nuvem, permissões e ciclo de vida (10-13)	Decisões justificadas.
105-115 min	Intervalo	Pausa de 10 minutos.
115-140 min	Operação e riscos (14-17)	Leitura crítica e priorização.
140-155 min	Inventário da empresa fictícia (18)	Mapa das identidades.
155-200 min	Atividade guiada (19-21)	Correções e testes propostos.
200-215 min	Estudo de caso (22)	Plano de resposta ao incidente.
215-235 min	Desafio final (23)	Desenho de arquitetura segura.
235-240 min	Autoavaliação (24)	Registro individual de aprendizagem.

Total: 240 minutos, incluindo o intervalo. As microtarefas fazem parte dos blocos indicados. O checklist da página 25 e as referências das páginas 26-27 apoiam a consulta posterior.

O que significa atingir o objetivo

Você deverá identificar NHIs, separar identidade de credencial, definir permissões mínimas, escolher um mecanismo de autenticação e propor rotação, revogação, auditoria e encerramento com responsável definido.

Use papel ou um editor de texto. Registre hipóteses quando faltarem dados. Os exemplos não representam sistemas nem políticas internas da J&J. As configurações são pseudoconfigurações didáticas, não instruções prontas para implantação.

2. Quem são as identidades não humanas?

NHI significa *non-human identity*, ou identidade não humana. É uma identidade usada por software, serviço, automação ou dispositivo para interagir com recursos digitais. Nesta aula, o recorte principal são as identidades de serviço e de cargas de trabalho.

Workload, ou carga de trabalho, é uma aplicação ou conjunto de processos que entrega uma função: processar pedidos, gerar relatórios ou executar um robô. O workload utiliza uma identidade; o programa, a identidade e a credencial não são o mesmo objeto.

Elemento	Exemplo corporativo	Ponto de atenção
Conta de serviço	Processo noturno lê pedidos no banco.	Evitar conta pessoal e login interativo desnecessário.
Service principal	Representação de aplicação em um diretório.	Identificar o produto e o escopo do objeto.
Bot / robô	Automação abre chamados de falha.	Limitar canais, projetos e operações.
Pipeline CI/CD	Processo testa e publica uma aplicação.	Separar a identidade de publicação da aplicação.
API e consumidor	Sistema de estoque chama a API de pedidos.	A API é uma interface; o consumidor precisa de identidade quando o acesso é protegido.

Pessoas continuam responsáveis

A proprietária de negócio explica por que a integração existe. A equipe técnica mantém sua execução. Segurança e IAM apoiam controles e revisão. Uma conta chamada “integracao” não informa quem responde por ela nem quais dependências serão afetadas ao bloqueá-la.

Exemplo corporativo

O robô que envia avisos de manutenção precisa publicar em um canal específico. A pessoa que o desenvolveu pode sair da empresa sem que o robô pare, desde que a identidade pertença ao serviço e tenha responsáveis atualizados.

Microtarefa 1

Liste três programas que agem sem interação humana em uma empresa. Para cada um, indique recurso acessado, ação necessária e equipe que deveria responder pelo acesso.

3. Vocabulário: identidade não é segredo

Termo	Significado	Exemplo fictício
Identidade	Representação de quem ou do que atua no sistema.	Serviço de conciliação de pedidos.
Conta	Registro administrável que representa uma identidade em determinado sistema.	svc-conciliacao-prod.
Credencial	Elemento ou conjunto de elementos usado para comprovar uma identidade ou sustentar acesso.	Certificado com prova de posse da chave privada.
Segredo	Valor confidencial cuja divulgação compromete a proteção prevista.	Senha, chave privada ou token bearer.
Chave de API	Valor usado por uma API para identificar o cliente/projeto e, conforme o serviço, autorizar chamadas.	CHAVE_FICTICIA_SEM_VALIDADE.
Token de acesso	Artefato apresentado ao recurso para acessar operações autorizadas durante sua validade.	Token emitido para a API de estoque.
Identificador público	Nome ou ID que aponta para um objeto; sozinho não comprova identidade.	client_id ou nome da conta.

A palavra **chave** é ambígua: uma chave de API não é necessariamente uma chave criptográfica. Em criptografia assimétrica, a chave privada é secreta; a chave pública pode ser distribuída. Um certificado público também não precisa ser secreto.

Conexão entre os elementos

O serviço de relatórios é o workload. “svc-relatorios-prod” é sua conta no cenário. A política limita a leitura a relatórios autorizados. O mecanismo de autenticação fornece a credencial necessária. Trocar a credencial não significa criar uma nova identidade.

No Microsoft Entra ID, o **service principal** representa a aplicação em um tenant, isto é, um diretório organizacional. O objeto de aplicação funciona como sua definição; não é sinônimo do service principal. Uma identidade gerenciada também é representada por um tipo específico de service principal. [1]

Microtarefa 2

Classifique: nome de conta, senha de banco, client_id, token de acesso e chave privada. Quais precisam ser protegidos como segredo? Quais ajudam a localizar uma identidade, mas não demonstram sozinhos sua autenticidade?

4. Credenciais estáticas e temporárias

Uma credencial **estática** é reutilizada até ser substituída, expirar ou ser desativada. Ela pode ter data de expiração. Uma credencial **temporária** nasce com validade curta e é obtida novamente por um fluxo autorizado. O tempo curto reduz a janela de uso de uma cópia vazada, mas não corrige permissões excessivas.

Critério	Estática / longa duração	Temporária / curta duração
Exemplo	Senha de banco ou chave de API reutilizada.	Credenciais de sessão de uma role ou token de acesso.
Distribuição	Exige guardar e entregar o valor com segurança.	Obtida em execução por identidade confiável.
Manutenção	Rotação planejada e atualização dos consumidores.	Renovação automática, tratamento de expiração e falhas.
Risco principal	Cópias antigas permanecem válidas por muito tempo.	Invasor usa o token durante a validade ou obtém novos tokens.
Dependência	Cofre e processo de atualização.	Emissor, relógios, confiança e permissões corretas.

De onde vem a confiança inicial?

Para obter uma credencial temporária, o serviço precisa provar que está autorizado. Isso pode ocorrer por identidade fornecida pela plataforma, federação de workload ou um segredo inicial. Se a renovação depende de uma chave estática, essa chave continua exigindo proteção.

Federação permite confiar em uma identidade atestada por outro emissor, sob condições verificadas. Prefira identidades gerenciadas ou federação quando compatíveis. No acesso de workloads à AWS, a orientação oficial privilegia credenciais temporárias por IAM roles. [2]

Escolha orientada pela necessidade

Um serviço legado pode aceitar apenas senha. Nesse caso, documente a limitação, reduza permissões, use armazenamento controlado e teste a troca. Defina responsável e plano de evolução; não transforme a exceção em padrão para todos os novos serviços.

Microtarefa 3

Uma automação usa token de 15 minutos, mas mantém uma chave permanente capaz de gerar novos tokens. Qual risco ainda existe? Que alternativa você investigaria e que evidência pediria para confirmar sua viabilidade?

5. OAuth 2.0: acesso entre serviços

OAuth 2.0 é um framework de autorização. Ele permite que um cliente obtenha um token para acessar um recurso protegido. Não é um formato de token e, sozinho, não é um protocolo de login de usuários. [3]

Participante	Função no exemplo
Cliente	Serviço que precisa consultar o estoque.
Servidor de autorização	Verifica o cliente e emite token conforme as concessões.
Servidor de recurso	API que valida o acesso antes de entregar o estoque.
Responsável pelo recurso	Organização que define as concessões aplicáveis.

Fluxo conceitual de client credentials

1. O cliente confidencial, capaz de proteger suas credenciais, autentica-se no servidor de autorização.
2. Solicita o acesso permitido para atuar em nome próprio.
3. Recebe um token de acesso com validade e autorização delimitadas.
4. Apresenta o token à API por canal protegido.
5. A API verifica o token e a autorização da operação. [3]

No fluxo *client credentials*, normalmente não há pessoa delegando uma sessão. A autenticação do cliente pode usar segredo, certificado ou outro método suportado. Não coloque credenciais desse tipo em um aplicativo de navegador distribuído aos usuários.

Scope e audience respondem a perguntas diferentes

Escopo (scope): qual conjunto de operações foi concedido? Exemplo didático: estoque.ler.
Destinatário (audience / aud): qual API deve aceitar o token? Exemplo: api-estoque.
Ter escopo de leitura não autoriza usar o token em qualquer API.

Um token **bearer** pode ser usado por quem o possuir, sem prova adicional de posse de chave. Por isso, TLS/HTTPS e proteção contra vazamento são essenciais. Não coloque tokens em URLs, tickets, chats ou registros de depuração. [4]

Microtarefa 4

Um serviço só precisa consultar disponibilidade. Descreva a audience e um escopo apropriados, e cite uma operação que a API deverá negar mesmo com o token válido.

6. JWT: ler não significa validar

JWT, *JSON Web Token*, é um formato de declarações (*claims*). Um token de acesso pode ser JWT ou opaco, sem conteúdo legível para o cliente. No JWT assinado em formato compacto comum, há cabeçalho, conteúdo e assinatura. Codificação Base64url não é criptografia. [5]

Campo	O que verificar conceitualmente
iss (issuer)	O emissor é exatamente um dos confiáveis?
sub (subject)	Qual sujeito é representado e como ele é mapeado?
aud (audience)	Esta API está entre os destinatários previstos?
exp (expiration)	O token ainda está dentro da validade?
nbf / iat	Quando pode começar a valer / quando foi emitido?
scope ou roles	O perfil adotado informa a operação necessária? Os nomes variam.

Nem todos os campos são obrigatórios em todo JWT. O perfil do sistema define requisitos. Para a API do exercício, exigimos emissor, destinatário, expiração e autorização da operação. As datas são exibidas de modo legível no material; em JWT real, campos de tempo usam a representação definida pelo padrão. [5]

O que a API precisa fazer

Use uma biblioteca apropriada para validar assinatura, algoritmo permitido e chave confiável, além das declarações exigidas. Não aceite o algoritmo apenas porque o token o anunciou. Decodificar o conteúdo ou encontrar um nome conhecido não autentica a solicitação. Regras de validação devem distinguir os tipos de token e impedir sua troca indevida. [6]

Exemplo conceitual, sem token real

Um token destinado à “api-relatorios” chega à “api-pagamentos”. Mesmo que a assinatura seja válida, o destinatário precisa ser conferido. Da mesma forma, “estoque.ler” não concede “estoque.excluir”. A política do recurso ainda participa da decisão.

Um JWT assinado normalmente tem conteúdo legível. Não inclua senhas nem dados pessoais desnecessários em suas declarações. Um ID token de OpenID Connect tem finalidade diferente de um access token; não os trate como intercambiáveis. [6]

Microtarefa 5

Explique por que “consegui abrir o JWT em um site” não comprova validade. Quais riscos surgem ao colar um token real em um decodificador externo?

7. Expiração, revogação e chaves de API

Expiração encerra a validade prevista. **Revogação** busca retirar a validade antes desse prazo. O OAuth define um mecanismo de revogação, mas seu efeito sobre tokens já apresentados aos recursos depende da implementação e da propagação. [7]

Uma API que verifica um JWT somente de forma local pode continuar aceitando-o até a expiração, se não consultar estado de revogação nem aplicar outro bloqueio. Retirar o segredo do cliente impede certas novas emissões, mas não garante invalidar todos os tokens já emitidos. Teste o comportamento real. [7]

Ação	O que precisa ser confirmado
Revogar uma chave de API	Ela deixou de funcionar em todos os pontos de entrada?
Desabilitar o cliente	Novas emissões foram impedidas? Tokens existentes ainda funcionam?
Retirar uma permissão	Onde a autorização é reavaliada? Há caches ou atraso?
Bloquear no recurso	A operação crítica ficou indisponível ao sujeito comprometido?

Chaves de API: proteção e limites

As capacidades variam por serviço: algumas chaves identificam projeto e contabilizam consumo; outras concedem acesso sensível. Verifique restrições de API, recurso, origem e expiração, quando disponíveis. Para dados críticos, não presuma que uma chave isolada oferece autenticação e autorização suficientes. [8]

Trate uma chave que permite acesso como segredo. Evite colocá-la na URL, no código ou em aplicativos públicos. Restrição por IP pode ajudar, mas não substitui permissão mínima. Quotas e limites de taxa reduzem abuso de consumo; não decidem sozinhos quais dados podem ser lidos. [8]

Dois relógios diferentes

A identidade pode existir por anos enquanto cada token vale minutos. O inventário acompanha a identidade; o controle de emissão e revogação acompanha suas credenciais. Excluir uma cópia local da chave não revoga o valor no provedor.

Microtarefa 6

Após um vazamento, a equipe troca a senha do cliente e declara o incidente encerrado. Que verificações faltam sobre tokens existentes, permissões, dados acessados e continuidade do serviço?

8. Certificados e mTLS

Um certificado digital associa uma chave pública a informações de identidade, sob a assinatura de um emissor. A chave privada correspondente deve permanecer protegida. A autenticação depende de demonstrar sua posse e validar a confiança; copiar um certificado público não equivale a possuir a identidade.

No TLS habitual de uma conexão HTTPS, o cliente verifica o servidor. No **mTLS** (*mutual TLS*), cliente e servidor se autenticam com certificados. Isso é útil em comunicações entre serviços, desde que exista gestão de emissão, confiança, renovação e desligamento. [9]

Mecanismo	O que oferece	O que continua necessário
Chave de API	Apresentação de um valor reconhecido pelo serviço.	Proteção da chave, restrições e autorização.
Token bearer	Acesso conforme o token aceito pelo recurso.	Proteger a posse, validar e limitar a validade.
Certificado + mTLS	Autenticação de ambas as pontas e canal protegido.	Proteger chave privada e mapear identidade para permissões.

Certificado válido não significa acesso irrestrito

A API precisa associar o cliente autenticado às operações permitidas. Em integrações OAuth específicas, o token pode ser vinculado a um certificado, exigindo prova de posse da chave para utilizá-lo. Isso não ocorre automaticamente só porque existe HTTPS. [9]

Exemplo corporativo

Um equipamento de coleta envia medições a um serviço central. Um certificado individual permite identificar o equipamento. A política autoriza envio de medições daquele dispositivo, mas não leitura de todos os relatórios nem administração de outros equipamentos.

No planejamento, registre quem emite certificados, quais autoridades são confiáveis, como a expiração será alertada e como o recurso lidará com revogação. Renove antes do vencimento e teste a cadeia de confiança. Certificados e chaves privadas não devem ser confundidos no inventário.

Microtarefa 7

Se dois serviços compartilham a mesma chave privada, que dificuldades surgem para auditoria e bloqueio de apenas um deles? Proponha como separar a responsabilidade.

9. AWS, Azure e Google Cloud

Os três ecossistemas permitem reduzir o uso de segredos permanentes, mas seus objetos e regras não são equivalentes. Primeiro descreva a necessidade; depois escolha o mecanismo do provedor.

Plataforma	Modelo	Cuidados
AWS IAM Roles	Role é uma identidade assumível com políticas. Uma sessão de role recebe credenciais temporárias via mecanismos de STS.	A confiança define quem pode assumir; as políticas definem o acesso. Role não tem chave permanente própria. [10]
Azure Managed Identities	Identidade gerenciada representada no Entra ID. O workload obtém tokens sem administrar diretamente um segredo.	System-assigned acompanha o recurso; user-assigned tem ciclo independente e pode ser associada a vários recursos. Conceda acesso no destino. [11]
Google Cloud service accounts	Conta usada por aplicações, que pode receber papéis IAM. Pode ser associada ao recurso ou usada por fluxos de federação/impersonação.	A conta não é seu arquivo de chave JSON. Prefira alternativas às chaves exportadas quando possível. [12]

Três aplicações da mesma necessidade

AWS: uma função de processamento usa sua role de execução para obter acesso apenas ao local necessário. A role pode existir por longo prazo; a sessão expira.
Azure: um serviço compatível usa managed identity; uma atribuição de papel apropriada autoriza o acesso ao recurso de dados.
Google Cloud: o workload utiliza uma service account autorizada, com credenciais temporárias obtidas pelo mecanismo suportado. [10-12]

Não confunda os modelos

Um papel RBAC é um conjunto de permissões. Uma AWS IAM role também é uma identidade assumível. Uma Azure managed identity é uma identidade, não um papel. Uma Google Cloud service account recebe papéis, mas não é o próprio papel. A ServiceAccount do Kubernetes é outro objeto.

Gerenciamento automático da credencial não elimina a gestão de permissões, ownership e desligamento. Recursos compatíveis, condições de confiança e efeitos de revogação devem ser confirmados na documentação do produto.

Microtarefa 8

Escolha uma das três nuvens e explique: qual é a identidade, quem pode utilizá-la, como obtém credenciais e onde ficam definidas as permissões sobre o recurso?

10. Menor privilégio e separação

Least privilege, ou menor privilégio, concede somente ações necessárias sobre recursos delimitados, durante o período e nas condições apropriadas. A existência de uma automação não justifica acesso administrativo. RBAC pode associar a identidade a papéis restritos. [2, 13]

Identidade fictícia	Necessidade	Limite proposto
svc-relatorio-prod	Ler pedidos consolidados.	Somente leitura da visão consolidada; sem cadastro de usuários.
bot-alertas-prod	Publicar alertas operacionais.	Somente canal de operação; sem exportar conversas.
ci-publicador-prod	Publicar uma versão aprovada.	Somente aplicação alvo; sem ler o banco de clientes.
svc-relatorio-teste	Validar mudanças.	Dados sintéticos e recursos de teste.

Separar execução, administração e ambientes

Use identidades distintas quando as funções, os riscos ou os ambientes forem diferentes. Desenvolvimento, homologação e produção devem ter acessos delimitados. A credencial de teste não deve abrir produção. Quem altera a política de acesso não precisa ser o mesmo sujeito que publica ou processa dados.

Uma identidade de implantação pode ter poder de alterar o código que receberá acesso a dados. Portanto, não basta retirar dela a leitura direta do banco: proteger a aprovação e a integridade da publicação também importa. Esse é um caminho indireto de privilégio.

Como validar a intenção

Para “ler relatórios de produção”, escreva um teste permitido de leitura e testes negados de exclusão, leitura de outro conjunto e uso a partir de teste. Examine permissões herdadas e delegação: o papel local pode parecer restrito enquanto outra concessão amplia o acesso.

Evite curingas de ação e recurso sem justificativa. Quando uma operação exigir abrangência maior por limitação técnica, registre a exceção, o controle compensatório, o aprovador e a data de revisão.

Microtarefa 9

Um bot precisa criar chamados, mas recebeu administrador global. Escreva uma necessidade de negócio verificável, um papel mínimo e três testes de negativa.

11. Ciclo de vida e inventário

Gerenciar uma identidade de serviço é manter um vínculo verificável entre finalidade, execução e permissão. O processo abaixo é uma proposta didática de operação, alinhada à gestão de contas, autenticadores e menor privilégio. [13]

Etapa	Ação e evidência esperada
Inventário	Descobrir serviços, contas, integrações e dependências; registrar dono e finalidade.
Criação	Aprovar necessidade, ambiente, nome, responsável e mecanismo de autenticação.
Provisionamento	Associar workload e identidade; conceder permissões; entregar acesso de modo controlado.
Uso	Obter credencial e executar apenas as operações aprovadas.
Monitoramento	Correlacionar uso, mudanças de política, falhas e comportamento esperado.
Rotação	Substituir credenciais que exigem troca, atualizar consumidores e testar.
Revogação	Retirar acesso ou validade quando houver risco ou fim da necessidade.
Desprovisionamento	Remover vínculos e objetos sem uso; preservar evidências conforme política.

Ficha mínima de inventário

Identificação: ID único, nome, tipo, sistema e ambiente.
Negócio: finalidade, proprietário responsável e equipe substituta.
Acesso: recursos, ações, papéis e quem pode assumir/usar a identidade.
Credencial: tipo, referência no cofre, validade e processo de renovação; nunca o valor secreto.
Operação: consumidores, último uso observado, logs, revisão e desligamento.

Ownership é uma obrigação operacional

O responsável valida se o serviço ainda deve existir e responde às revisões. O operador executa mudanças; o aprovador confirma o acesso. “Equipe de TI” sem contato, substituto ou prazo de revisão deixa uma responsabilidade ambígua.

Microtarefa 10

Uma conta não aparece nos logs há 60 dias. Antes de excluí-la, que dependências e rotinas sazonais você verificaria? Como registraria uma decisão de manter ou desativar?

12. Rotação, revogação e encerramento

Rotação é uma mudança de credencial planejada para preservar o serviço. Revogação prioriza impedir uso não autorizado. Em um incidente, pode ser necessário aceitar interrupção controlada para conter o dano. O procedimento deve considerar dependências e risco.

Roteiro de rotação para uma integração fictícia

1. Identificar todos os consumidores e a janela de mudança.
2. Criar uma nova versão de credencial com permissões restritas.
3. Entregar a nova versão pelo canal aprovado.
4. Atualizar e testar cada consumidor.
5. Invalidar a anterior e comprovar que ela falha.
6. Registrar evidências e observar erros após a mudança.

Se o serviço aceitar duas chaves simultâneas, uma sobreposição curta pode facilitar a troca. Se aceitar apenas uma, planeje a atualização coordenada. O prazo de troca depende do risco e do mecanismo; não existe um intervalo único adequado a todos os segredos. Chaves exportadas de service accounts exigem gestão explícita de suas cópias e substituição. [14]

Evento	Pergunta para a operação
Chave vazada	Como bloquear o uso e impedir novas credenciais derivadas?
Certificado perto de vencer	Os consumidores reconhecerão a nova cadeia e chave?
Aplicação encerrada	Restaram jobs, permissões, chaves ou integrações?
Mudança de responsável	Quem assumiu a revisão e os alertas?
Falha durante a troca	Há recuperação controlada sem reutilizar segredo comprometido?

No encerramento, retire concessões e confiança, interrompa execuções, revogue credenciais, remova vínculos e só então elimine objetos conforme o procedimento aprovado. Verifique sessões e caches remanescentes. Preserve o histórico necessário para auditoria sem preservar valores secretos em relatórios.

Microtarefa 11

Escreva um plano de troca para um robô que executa a cada hora e não pode perder pedidos. Defina teste de continuidade, teste de rejeição da credencial anterior e condição de interrupção segura.

13. Onde guardar e como entregar segredos

Um **secrets manager** é um serviço de armazenamento e entrega controlada de segredos. Exemplos incluem AWS Secrets Manager, Azure Key Vault e Google Cloud Secret Manager. O acesso ao cofre também exige identidade e autorização; mover uma senha para o cofre não resolve acesso amplo a todos os segredos. [15]

Opção	Uso e limitação
Cofre de segredos	Centraliza controle, versões e auditoria. Restrinja a leitura por aplicação e ambiente.
Variável de ambiente	Pode entregar um valor ao processo, mas não é um cofre. Pode aparecer em diagnósticos, subprocessos ou ferramentas com privilégios.
Arquivo montado em execução	Pode limitar exposição e permissões locais. Proteja leitura, cópias, backups e descarte.
Arquivo .env	É texto local, não criptografia. Não deve entrar no Git nem em imagens e artefatos.

Prefira acesso por identidade da plataforma quando possível. Se precisar de segredo, entregue-o somente ao consumidor autorizado e evite persistência desnecessária. Considere disponibilidade do cofre e comportamento seguro se a leitura falhar. [15]

Regra operacional: credenciais fora de Git e logs

Não registre senhas, chaves privadas, chaves de API nem tokens de acesso em código, histórico Git, logs, imagens ou anexos de chamados. Um repositório privado também não é cofre. Arquivos ignorados ajudam a prevenir novos commits, mas não removem valores já versionados. [14, 16]

Exemplo de evidência sem segredo

Registre “identidade=svc-estoque-prod; operação=ler; recurso=estoque; resultado=permitido; requisição=REQ-104”. Se precisar identificar uma versão, registre seu ID administrativo não secreto. Nunca copie o cabeçalho Authorization completo para o log.

O processo autorizado ainda pode ler um segredo recebido. Portanto, proteger o runtime, limitar depuração e controlar quem altera o código fazem parte da proteção.

Microtarefa 12

Uma equipe diz que suas chaves estão seguras porque foram movidas do código para variáveis de ambiente. Que perguntas você faria sobre origem, leitura, logs, renovação e acesso ao processo?

14. CI/CD, containers e automações

CI/CD automatiza integração, testes e entrega de software. O pipeline é um sujeito de acesso poderoso: pode publicar código e influenciar a identidade que o código utilizará em produção.

Confiança delimitada no pipeline

Quando suportado, a federação com OIDC permite apresentar uma identidade verificável da execução e obter credenciais de curta duração. Restrinja emissor, destinatário e atributos do job autorizado, como repositório, referência e ambiente, conforme o formato aceito pela plataforma. Não confie em qualquer execução de qualquer repositório. [17]

Separe testes sem acesso à produção de publicação aprovada. Mudanças não confiáveis não devem executar com segredos de produção. Controle quem altera workflows, dependências e aprovações; um token temporário não impede abuso enquanto o job autorizado está comprometido.

Containers e Kubernetes

Não grave segredos em Dockerfile, camadas de imagem ou artefatos de build. Entregue-os em execução quando necessários. Em Kubernetes, Base64 em um objeto Secret não é criptografia; controle RBAC, criptografia em repouso e quais pods podem receber cada segredo. [18]

Uma **Kubernetes ServiceAccount** identifica workloads perante o cluster; não é automaticamente uma service account do Google Cloud. A integração com identidades de nuvem precisa de configuração explícita. Evite compartilhar uma identidade privilegiada entre aplicações distintas.

Componente	Pergunta de revisão
Job de build	Precisa realmente acessar dados de produção?
Job de deploy	Publica só a aplicação e o ambiente aprovados?
Container em execução	Usa identidade própria e permissões mínimas?
Automação agendada	Tem owner, alertas, renovação e plano de desligamento?

Exemplo corporativo

O job de teste compila com dados sintéticos. O job de produção publica somente após aprovação. A aplicação usa outra identidade para consultar os dados autorizados. Avalie também quem pode modificar o código publicado: essa capacidade pode afetar o acesso em execução.

15. Auditoria e sinais de incidente

Auditar é conseguir reconstruir quem fez o quê, em qual recurso, quando e com que resultado. Registre também concessões, alterações de confiança e emissão ou revogação de credenciais, sem expor seu conteúdo. Proteja os registros contra alteração e acesso indevido. [16]

Sinal	Hipótese a investigar
Uso fora da origem ou horário esperado	Execução legítima mudou ou credencial foi copiada?
Aumento de leitura, exportação ou custo	Nova rotina, erro de repetição ou abuso?
Novas chaves e papéis amplos	Mudança aprovada ou tentativa de persistência?
Identidade encerrada continua acessando	Consumidor esquecido, sessão ou revogação incompleta?
Muitas negativas após rotação	Consumidor antigo ou nova configuração incorreta?

Exemplo de incidente A: chave no repositório

Em um cenário fictício, um script de teste contém uma chave de produção e é publicado no Git. Minutos depois, surgem chamadas de uma origem desconhecida. Apagar a linha reduz exposição futura, mas não impede o uso de cópias já obtidas. A resposta precisa alcançar a chave no sistema que a aceita. [14]

Exemplo de incidente B: token no log

Em outro cenário fictício, o modo de depuração registra Authorization. Uma pessoa com acesso ao painel de logs copia o token e chama a API enquanto ele é válido. Retenção curta do log não substitui prevenção de exposição nem validação de autorização.

Sequência de resposta para discutir

Acionar responsáveis e registrar o evento; conter a credencial e o acesso afetado; preservar evidências; investigar operações e alcance; recuperar com acesso mínimo; verificar bloqueio e continuidade; corrigir o caminho que expôs o segredo. A ordem operacional deve considerar urgência e dependências.

Indício de acesso não prova automaticamente exfiltração; ausência de log também não prova ausência de dano. Diferencie fatos observados, hipóteses e dados que ainda precisam ser obtidos.

16. Matriz de riscos operacionais

A matriz abaixo é uma ferramenta didática de priorização. Não representa a metodologia interna da J&J. Avalie o risco antes e depois dos controles e registre o que permanece desconhecido.

Probabilidade (P): 1 = acesso restrito e exploração pouco provável; 2 = exposição possível; 3 = exposição ampla ou exploração plausível.
Impacto (I): 1 = efeito local recuperável; 2 = interrupção ou dados de alcance limitado; 3 = produção, dados críticos ou dano amplo.

P × I	I = 1	I = 2	I = 3
P = 1	1 - baixo	2 - baixo	3 - médio
P = 2	2 - baixo	4 - médio	6 - alto
P = 3	3 - médio	6 - alto	9 - alto

Cenário ilustrativo	P / I	Risco	Controle a avaliar
Chave de produção em Git público	3 / 3	9 - alto	Revogar e investigar; prevenir novo commit.
Token amplo disponível a job não confiável	3 / 3	9 - alto	Restringir confiança e separar jobs.
Certificado vence sem alerta	2 / 2	4 - médio	Inventariar validade e testar renovação.
Conta sem owner, com acesso residual	2 / 3	6 - alto	Definir responsabilidade e revisar dependências.

Os valores são premissas dos exemplos, não medições universais. Se houver exploração ativa ou vazamento confirmado, contenha o incidente sem aguardar uma pontuação perfeita. Um controle planejado só reduz o risco depois de implementado e verificado.

Aplicação individual

Escolha um cenário diferente dos exemplos. Registre: ativo, ameaça, fragilidade, consequência, P, I, justificativa, controle proposto, responsável e evidência de eficácia. Reavalie o risco residual sem presumir que ele será zero.

17. Atividade: descobrir NHIs na Aurora

Tempo: 15 minutos | Entrega: inventário inicial. A Aurora Distribuição é fictícia. Em duplas, leiam os fatos, identifiquem sujeitos de acesso e anotem o que precisa ser investigado. Não existe obrigação de criar uma conta para cada software citado.

Situação da empresa

A Aurora recebe pedidos em um portal. Um processo noturno consolida vendas no banco; um bot abre chamados de atraso; um job publica novas versões; um conector consulta uma transportadora; um sensor envia temperatura ao serviço central; uma analista acessa o painel com sua conta pessoal. Um robô antigo de exportação continua instalado, mas ninguém sabe quem o mantém.

Passos da atividade

1. Identificar (4 min): separe pessoas, workloads, APIs e candidatos a identidades não humanas.
2. Relacionar (7 min): para cada NHI candidata, indique finalidade, recurso, ação, ambiente e responsável a confirmar.
3. Priorizar (4 min): escolha duas lacunas do inventário e explique o risco de deixá-las sem investigação.

Workload / identidade	Recurso e ação	Ambiente / owner	Dúvida a verificar
1. _____	_____	_____	_____
2. _____	_____	_____	_____
3. _____	_____	_____	_____
4. _____	_____	_____	_____
5. _____	_____	_____	_____
6. _____	_____	_____	_____

Use o verso ou um documento separado para detalhar. A ficha não deve conter senhas nem tokens. “Responsável a confirmar” é um registro válido de lacuna; inventar um owner conhecido não é.

Perguntas para discussão

Que automações não podem depender da conta da analista? Onde uma mesma identidade poderia estar sendo reutilizada? Como verificar o robô antigo sem desligar um processo importante por engano? Que evidência distingue uma API de seu consumidor?

18. Prática guiada: analisar configurações

Tempo total: 45 minutos | Recursos: este PDF e papel/editor. O objetivo é propor correções e testes. Não execute comandos, não crie contas cloud e não substitua os marcadores por credenciais reais. Todos os nomes e valores são fictícios.

Necessidade aprovada da Aurora

O serviço **consulta-estoque** só pode ler a disponibilidade do depósito A em produção. Homologação usa dados sintéticos. O pipeline **aurora/estoque** pode publicar nessa aplicação após aprovação do ambiente produção. O bot de alertas só pode criar chamados na fila Operações. Nenhum deles administra identidades.

Configuração A - aplicação

identidade: svc-compartilhada
consumidores: consulta-estoque, bot-alertas, deploy
ambientes: homologacao, producao
permissoes: todas_as_acoes em todos_os_recursos
tipo_credencial: chave_estatica
valor: CHAVE_FICTICIA_SEM_VALIDADE
armazenamento: repositorio/config.env
log: registrar_todas_as_variaveis
owner: nao_informado

Configuração B - validação da API

api_receptora: api-estoque-prod
emissor_esperado: emissor-aurora
verificar_assinatura: sim
verificar_emissor: nao
verificar_audience: nao
verificar_expiracao: nao
escopo_exigido: nenhum
registrar_token_completo: sim

Nesta pseudoconfiguração, “sim” e “não” expressam comportamentos do cenário; não correspondem a opções reais de uma biblioteca. A existência de assinatura verificada não informa, sozinha, se o algoritmo e a chave foram escolhidos de forma confiável.

Passo 1 - compreender (5 minutos)

Sublinhe as necessidades de negócio. Em A e B, circule evidências que merecem revisão. Registre perguntas para aspectos não informados, distinguindo falha explícita de informação ausente. Continue com C e D na página seguinte.

19. Prática guiada: confiança e credenciais

Configuração C - pipeline e container

repositorio_autorizado: qualquer_repositorio
referencia_autorizada: qualquer_branch
emissor_oidc: emissor-ci-aurora
verificar_audience_oidc: nao
aprovacao_producao: dispensada
identidade_deploy: svc-compartilhada
imagem: inclui config.env na camada de build
runtime: usa a mesma identidade do deploy

Configuração D - ficha de credencial

tipo: chave de API da transportadora
restricoes_de_operacao: nao_configuradas
consumidores_conhecidos: conector e planilha antiga
responsavel: ex-colaborador
rotacao: sem procedimento
expiracao: nao_informada
revogacao_testada: nao
ultima_revisao: nao_registrada

Passo 2 - diagnosticar (10 minutos)

Selecione pelo menos **oito achados** entre A-D. Para cada um, copie somente a evidência não secreta, explique o risco e relacione-o a uma necessidade aprovada. Use a matriz da página 17 para escolher as três prioridades e justifique as pontuações.

Passo 3 - redesenhar (15 minutos)

Reescreva as quatro configurações em português ou pseudocódigo. Defina identidades, ambiente, permissões, confiança, forma de obtenção da credencial, armazenamento, owner e logs. Se uma integração só aceitar chave estática, proponha tratamento operacional e declare a limitação.

Estímulos para análise, sem respostas prontas

Quem pode pedir uma credencial? Para qual destino? Que ação deve funcionar? Qual deve falhar? Como o acesso será retirado? Quem confirma que a planilha antiga ainda é necessária? Onde ficará registrada a evidência de cada decisão?

Não é necessário adivinhar nomes exatos de papéis cloud. Uma proposta conceitual consistente é suficiente. Se optar por uma nuvem, use seus objetos corretos e indique o que depende de confirmação na documentação.

20. Prática guiada: provar a correção

Passo 4 - simular testes (10 minutos)

Agora simule as decisões da solução proposta. Preencha o resultado esperado e a evidência que procuraria em uma implementação. **Não há execução real:** não descreva um teste proposto como se já tivesse passado.

Teste proposto	Resultado e justificativa	Evidência a coletar
T1. Consulta do depósito A pela aplicação autorizada.	_____ _____	_____ _____
T2. Mesma identidade tenta excluir o estoque.	_____ _____	_____ _____
T3. Token para outra API chega à API de estoque.	_____ _____	_____ _____
T4. Token chega após sua expiração.	_____ _____	_____ _____
T5. Job de repositório não autorizado pede acesso a produção.	_____ _____	_____ _____
T6. Homologação tenta usar um recurso de produção.	_____ _____	_____ _____
T7. Consumidor usa a chave antiga após a troca.	_____ _____	_____ _____
T8. Serviço continua operando após renovação autorizada.	_____ _____	_____ _____

Passo 5 - revisão em dupla (5 minutos)

Troque a proposta com outra dupla. Peça que identifique uma permissão excessiva, uma dependência desconhecida ou um teste ausente. Se não encontrar, deverá explicar quais evidências sustentam essa avaliação.

Entrega da atividade

Um inventário revisado; oito achados com risco; quatro configurações propostas; oito testes; responsáveis e plano de rotação/revogação. A entrega deve declarar hipóteses e limitações, sem incluir valores secretos nem gabarito.

21. Estudo de caso: a chave exposta

Tempo: 15 minutos | Caso integralmente fictício. A Aurora migrou uma integração de transporte. Para acelerar um teste, uma chave de produção foi copiada para um arquivo. A equipe precisa decidir o que fazer com fatos ainda incompletos.

Horário	Evidência observada
09:00	O arquivo entra em um repositório público.
09:08	O scanner alerta sobre possível segredo.
09:12	A linha é apagada em um novo commit.
09:18	A API registra 4.000 consultas com a chave K-17, vindas de origem incomum. K-17 é apenas o ID administrativo.
09:25	A chave é desativada. A integração legítima para de funcionar.
09:35	Ainda há chamadas aceitas com tokens emitidos antes de 09:25. O recurso verifica esses tokens localmente.

Questões para decisão

1. O que é fato, hipótese e informação faltante? É possível concluir que houve vazamento de dados apenas com esses registros?
2. Por que apagar a linha não encerra o problema? Que evidências devem ser preservadas?
3. Como conter as chamadas remanescentes e verificar a efetividade do bloqueio?
4. Como recuperar a integração sem reativar o segredo comprometido?
5. Quem decide sobre continuidade, investigação e comunicação interna? Que informações cada responsável precisa receber?

Entrega do grupo

Produza um plano em três momentos: ações imediatas, recuperação controlada e prevenção de recorrência. Para cada ação, indique responsável, dependência, impacto no negócio e evidência de conclusão. Inclua o risco residual dos tokens já emitidos.

Use o modelo: “Fato observado → risco ou hipótese → ação proposta → como verificar”. Não copie tokens nem chaves para a ficha de incidente. Registre identificadores administrativos e referências às evidências sob acesso controlado.

22. Desafio final: arquitetura segura

Tempo: 20 minutos | Entrega: desenho + justificativa. A Aurora terá um portal de pedidos, um serviço de estoque, um bot de chamados, um banco e um pipeline de publicação. O conector da transportadora aceita apenas chave de API estática. Proponha uma arquitetura que gerencie essas identidades de ponta a ponta.

Restrições de negócio

Produção e homologação são separados. O serviço de estoque lê disponibilidade do depósito A; o portal registra pedidos; o bot cria chamados na fila Operações. O pipeline publica somente versões aprovadas. A integração deve continuar após a saída de qualquer desenvolvedor. Use dados fictícios.

O desenho deve mostrar

1. Workloads, identidades e responsáveis, com ambientes delimitados.
2. Emissor ou mecanismo de autenticação e caminho de obtenção de credenciais.
3. Recursos, ações permitidas e limites de confiança entre componentes.
4. Tratamento da chave estática e do acesso ao cofre.
5. Monitoramento, renovação, revogação e desprovisionamento.

Escolha tecnológica

Use AWS, Azure, Google Cloud ou um modelo independente de provedor. Se escolher uma nuvem, nomeie corretamente os objetos e não misture identidades, roles, contas e arquivos de chave. Justifique as exceções e indique decisões que exigem validação posterior.

Critério de avaliação	Evidência na entrega
Identidades e ownership	Cada função tem identidade e responsável justificáveis.
Menor privilégio	Ações e recursos estão delimitados por ambiente.
Credenciais e confiança	O desenho explica emissão, armazenamento e validação.
Ciclo de vida	Há procedimento de troca, bloqueio e encerramento.
Validação e continuidade	Há pelo menos dois testes permitidos, três negados e um teste de troca.

Organização sugerida: 3 minutos para requisitos, 10 para desenho e matriz de acessos, 5 para testes e 2 para justificar o maior risco residual. A avaliação considera coerência e evidências, não a quantidade de produtos utilizados.

23. Autoavaliação sem gabarito

Tempo em aula: 5 minutos. Para cada item, marque: **0** = ainda não explico; **1** = explico com apoio; **2** = explico e aplico. Escolha dois itens para responder por escrito durante a revisão posterior.

Consigo demonstrar que...	0 / 1 / 2
1. Distingo workload, identidade, conta, credencial e segredo.	_____
2. Reconheço NHIs em um processo corporativo e identifico seus owners.	_____
3. Explico o risco que permanece em uma credencial temporária.	_____
4. Diferencio OAuth 2.0 de JWT, scope de audience e access token de ID token.	_____
5. Explico por que decodificar um JWT não o valida.	_____
6. Distingo expiração, rotação e revogação e seus efeitos sobre sessões existentes.	_____
7. Comparo AWS IAM Roles, Azure Managed Identities e Google Cloud service accounts.	_____
8. Defino menor privilégio e separo identidades por função e ambiente.	_____
9. Explico limites de variáveis de ambiente, certificados e mTLS.	_____
10. Proponho controles para CI/CD, containers, Git e logs.	_____
11. Planejo resposta a chave exposta com contenção, evidências e recuperação.	_____
12. Testo e documento o ciclo de vida de uma identidade de serviço.	_____

Reflexão individual

Qual decisão do seu desenho depende de uma hipótese ainda não verificada? Que documento, teste ou pessoa ajudaria a confirmá-la? Qual controle você revisaria primeiro em uma integração existente?

A soma serve apenas para orientar o estudo. Ela não substitui a demonstração prática do objetivo “Gerenciar identidades de serviço”. Não há respostas nem gabarito neste material.

24. Checklist operacional de consulta

Marque **atendido**, **pendente** ou **não aplicável com justificativa**. Para cada pendência, registre responsável, prazo e evidência de conclusão. Use este checklist antes de publicar e nas revisões periódicas.

Verificação	Status / evidência
Inventário: finalidade, sistema, ambiente, ID e dependências registrados.	_____
Ownership: responsável ativo, substituto e aprovador conhecidos.	_____
Identidade: sem dependência indevida de conta pessoal ou compartilhamento amplo.	_____
Permissões: ações, recursos e delegação mínimos; acesso efetivo revisado.	_____
Ambientes: teste e produção com identidades e concessões delimitadas.	_____
Confiança: somente workloads e emissores autorizados obtêm credenciais.	_____
Tokens: assinatura, emissor, destinatário, validade e autorização verificados.	_____
Segredos: cofre e entrega restritos; nada em Git, imagens ou logs.	_____
CI/CD: código, jobs e aprovação protegidos; publicação separada da execução.	_____
Ciclo de vida: renovação, rotação, revogação e desligamento testáveis.	_____
Auditoria: eventos úteis, alertas, retenção e acesso aos registros definidos.	_____
Continuidade: consumidores mapeados e recuperação sem segredo comprometido.	_____

Vocabulário de consulta rápida

NHI: identidade não humana. **Workload:** carga de trabalho.
Owner: responsável pelo ciclo de vida. **Scope:** escopo de acesso.
Audience: destinatário previsto. **Claim:** declaração no token.
RBAC: controle por papéis. **mTLS:** autenticação TLS mútua.
Federação: confiança em identidade atestada por outro emissor.
Impersonação: atuação autorizada como outra identidade, sujeita a controles.

25. Referências confiáveis

Fontes oficiais e técnicas consultadas em 20/10/2026. Os números no texto apontam para esta lista. Títulos sublinhados são links clicáveis.

[1] Microsoft Learn. Application and service principal objects in Microsoft Entra ID.
Objetos de aplicação, service principals e tenants.

[2] AWS. Security best practices in IAM.
Credenciais temporárias, menor privilégio e revisão de acesso.

[3] IETF. RFC 6749: The OAuth 2.0 Authorization Framework (2012).
Seções 1 e 4.4: participantes e client credentials.

[4] IETF. RFC 6750: Bearer Token Usage (2012).
Uso e proteção de tokens bearer.

[5] IETF. RFC 7519: JSON Web Token (JWT) (2015).
Formato e declarações registradas de JWT.

[6] IETF. RFC 8725: JSON Web Token Best Current Practices (2020).
Validação, algoritmos e prevenção de confusão entre tokens.

[7] IETF. RFC 7009: OAuth 2.0 Token Revocation (2013).
Revogação e efeitos nos servidores de recurso.

[8] OWASP. REST Security Cheat Sheet.
Chaves de API, autorização e proteção de interfaces.

[9] IETF. RFC 8705: OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens (2020).
mTLS e tokens vinculados a certificados.

26. Referências e continuidade do estudo

Fontes oficiais e técnicas consultadas em 20/10/2026. Os números no texto apontam para esta lista. Títulos sublinhados são links clicáveis.

[10] AWS. IAM roles.
Identidade assumível e credenciais temporárias de sessão.

[11] Microsoft Learn. Managed identities for Azure resources.
Identidades system-assigned e user-assigned.

[12] Google Cloud. Service accounts overview.
Service accounts, uso por workloads e alternativas às chaves.

[13] NIST. SP 800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organizations.
Gestão de contas, menor privilégio e auditoria; controles AC-2, AC-6, IA-5 e família AU.

[14] Google Cloud. Best practices for managing service account keys.
Proteção, substituição e tratamento de chaves expostas.

[15] OWASP. Secrets Management Cheat Sheet.
Cofres, entrega, limitações e ciclo de vida de segredos.

[16] OWASP. Logging Cheat Sheet.
Registros úteis e exclusão de dados sensíveis dos logs.

[17] GitHub Docs. OpenID Connect.
Federação entre jobs e provedores de nuvem.

[18] Kubernetes. Good practices for Kubernetes Secrets.
RBAC, criptografia e exposição de segredos em workloads.

Para aprofundar: escolha a documentação do ambiente que você utiliza e compare seu procedimento de emissão, rotação e revogação com a arquitetura proposta. Confirme suporte e comportamento antes de implantar.